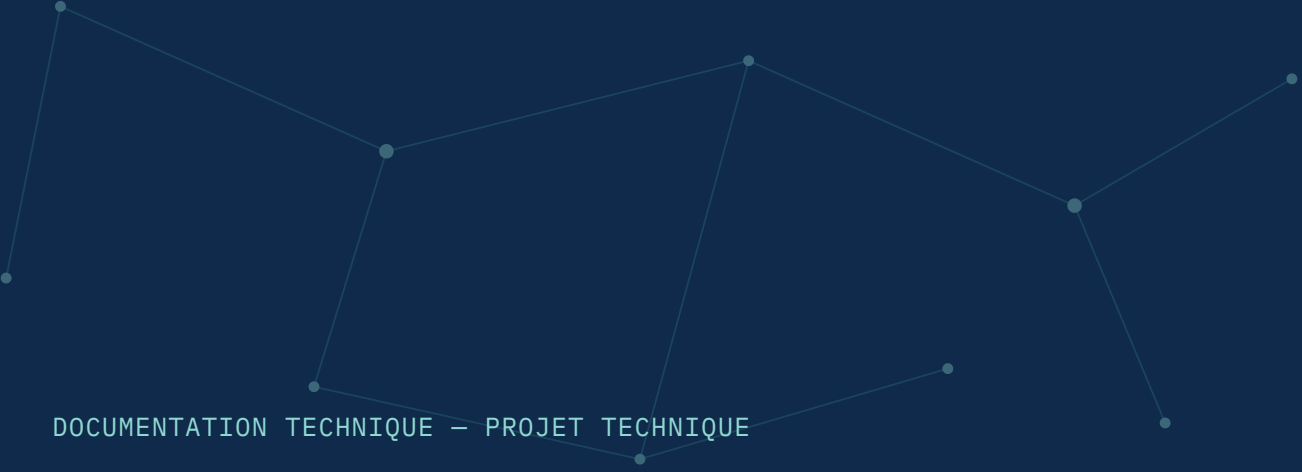




DOCUMENTATION TECHNIQUE – PROJET TECHNIQUE

# Infrastructure GLPI sécurisée

Architecture, configuration détaillée, procédures d'installation et d'exploitation de la plateforme de ticketing : GLPI 11 derrière un tunnel WireGuard, un pare-feu, une double authentification et un IPS Suricata.

---

Formation

Cybersécurité — audit et méthodologie,  
LiveCampus 2025

Encadrant

Laurent Coupeau

Version

1.0

Rédigé par

Bidault Dorian & Febbraro Enzo

Date

Vendredi 4 septembre 2026

Documents liés

Cahier des charges CDC-TICKETING-SEC-001,  
cahier de recettes, rapport de recette

## Sommaire

|    |                                      |    |
|----|--------------------------------------|----|
| 01 | Objet et périmètre                   | 3  |
| 02 | Architecture générale                | 4  |
| 03 | Virtualisation et réseau             | 7  |
| 04 | Serveur GLPI                         | 9  |
| 05 | Tunnel VPN WireGuard                 | 12 |
| 06 | Pare-feu et protection SSH           | 14 |
| 07 | Double authentification              | 16 |
| 08 | IPS Suricata                         | 17 |
| 09 | Poste client et agent GLPI           | 19 |
| 10 | Contrôle à distance                  | 20 |
| 11 | Collecteur de mails                  | 21 |
| 12 | Exploitation et maintenance          | 23 |
| 13 | Couverture des risques de sécurité   | 26 |
| 14 | Incidents rencontrés et corrections  | 28 |
| 15 | Dépôt Git et reproductibilité        | 30 |
| 16 | Limites et évolutions                | 31 |
| A  | Annexes : adresses, ports, commandes | 32 |

## 01 Objet et périmètre

Ce document décrit techniquement l'infrastructure livrée en réponse au cahier de recettes : ce qui est installé, comment c'est configuré, comment le reproduire et comment l'exploiter. Il complète le rapport de recette, qui apporte les preuves de conformité, et le dépôt Git, qui contient les scripts et fichiers de configuration.

Le périmètre couvre les deux machines virtuelles du laboratoire et tout ce qui s'y exécute. Il ne couvre pas l'hyperviseur Windows de l'hôte au-delà de la configuration VirtualBox nécessaire, ni les postes des utilisateurs finaux.

| Document                       | Rôle                                                                 | Emplacement                                   |
|--------------------------------|----------------------------------------------------------------------|-----------------------------------------------|
| <b>Documentation technique</b> | Ce document : architecture, configuration, procédures                | <code>docs/documentation-technique.pdf</code> |
| <b>Rapport de recette</b>      | Vérification point par point du cahier de recettes, captures d'écran | Livable séparé                                |
| <b>Guide de montage</b>        | Procédure pas à pas ayant servi au montage                           | <code>docs/guide-de-montage.pdf</code>        |
| <b>Dépôt Git</b>               | Scripts d'installation, configurations expurgées, outils             | <code>glpi-securise-infra/</code>             |

### Conventions

Les commandes précédées de `srv-glpi$` s'exécutent sur le serveur, celles précédées de `pc-client$` sur le poste client. Les valeurs secrètes (clés, mots de passe) sont remplacées par `<secret>` ; leur emplacement réel est donné en section 12.

## 02 Architecture générale

Deux machines sur un réseau privé. Le serveur n'expose qu'un seul port au réseau, celui du VPN ; tous les services applicatifs ne sont joignables qu'à l'intérieur du tunnel, où le trafic déchiffré est inspecté par l'IPS avant d'atteindre le pare-feu.

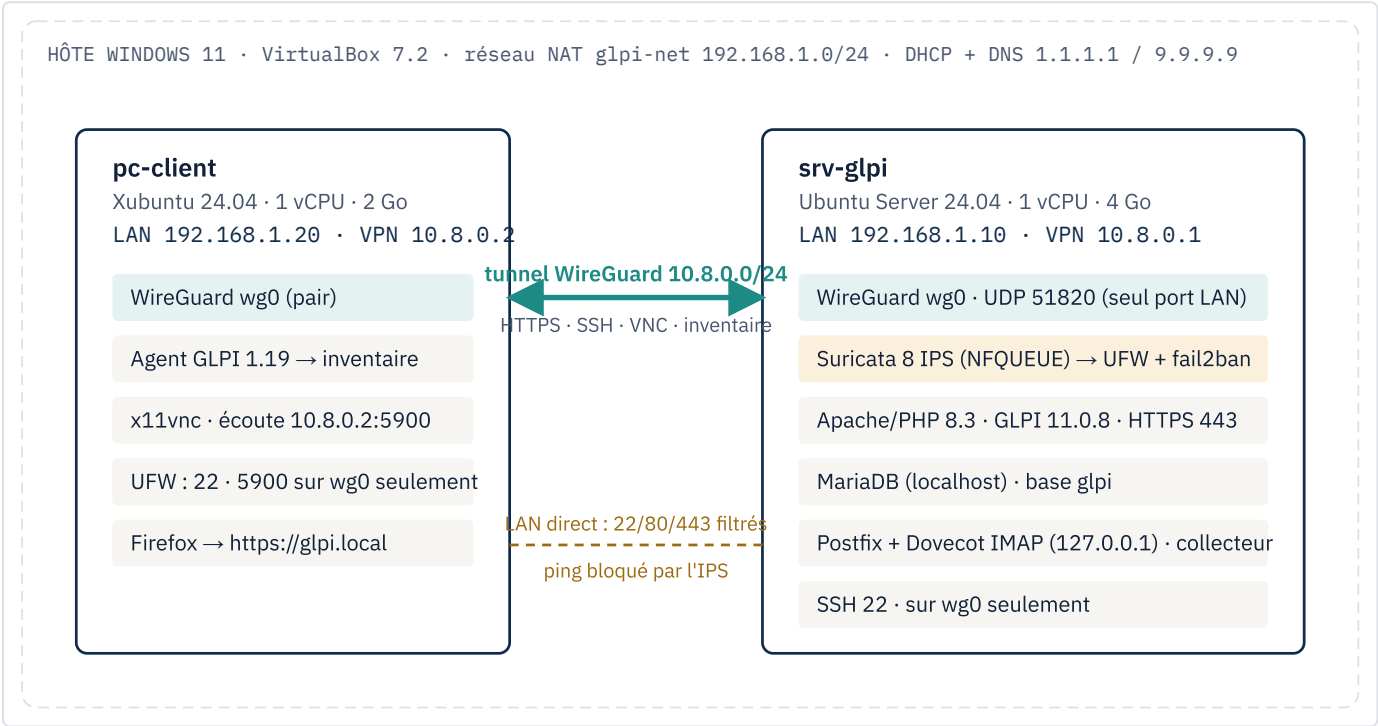


Figure 1 – Vue d'ensemble : le tunnel est l'unique chemin vers les services du serveur.

### Matrice des flux

| Source             | Destination              | Protocole / port                 | Chemin | Décision                                  |
|--------------------|--------------------------|----------------------------------|--------|-------------------------------------------|
| pc-client          | srv-glpi<br>192.168.1.10 | UDP 51820                        | LAN    | Autorisé<br>(établissement du tunnel)     |
| pc-client 10.8.0.2 | srv-glpi<br>10.8.0.1     | TCP 443 (GLPI), 80 (redirection) | Tunnel | Autorisé , inspecté par l'IPS             |
| pc-client 10.8.0.2 | srv-glpi<br>10.8.0.1     | TCP 22 (SSH)                     | Tunnel | Autorisé , journalisé par l'IPS, fail2ban |
|                    |                          |                                  |        |                                           |

| Source                            | Destination           | Protocole / port           | Chemin         | Décision                           |
|-----------------------------------|-----------------------|----------------------------|----------------|------------------------------------|
| poste d'administration (pair VPN) | pc-client 10.8.0.2    | TCP 5900 (VNC)             | Tunnel         | Autorisé                           |
| toute machine du LAN              | srv-glpi 192.168.1.10 | TCP 22, 80, 443            | LAN            | Filtré (UFW deny incoming)         |
| toute machine                     | srv-glpi              | ICMP echo                  | LAN ou tunnel  | Bloqué (règle IPS 9000003)         |
| toute machine                     | srv-glpi port 80      | HTTP contenant /etc/passwd | Tunnel         | Bloqué (règle IPS 9000002)         |
| srv-glpi, pc-client               | Internet              | HTTP/HTTPS, DNS            | NAT VirtualBox | Autorisé (mises à jour, règles ET) |

Composants et versions

| Composant              | Version                        | Machine   | Rôle                                                 |
|------------------------|--------------------------------|-----------|------------------------------------------------------|
| VirtualBox             | 7.2.16                         | hôte      | Hyperviseur, réseau NAT, DHCP, redirections de ports |
| Ubuntu Server          | 24.04.4 LTS, noyau 6.8         | srv-glpi  | Système du serveur                                   |
| Xubuntu                | 24.04.4 LTS, noyau 7.0         | pc-client | Système du poste client (bureau XFCE)                |
| GLPI                   | 11.0.8                         | srv-glpi  | Gestion de parc et de tickets                        |
| Apache / PHP / MariaDB | 2.4 / 8.3 / 10.11              | srv-glpi  | Pile web et base de données de GLPI                  |
| WireGuard              | module noyau + wireguard-tools | les deux  | Tunnel VPN chiffré                                   |
|                        |                                |           |                                                      |

| Composant               | Version            | Machine                            | Rôle                                    |
|-------------------------|--------------------|------------------------------------|-----------------------------------------|
| <b>UFW, fail2ban</b>    | 0.36 / 1.0         | srv-glpi (UFW aussi sur le client) | Pare-feu, bannissement des attaques SSH |
| <b>Suricata</b>         | 8.0.6 (dépôt OISF) | srv-glpi                           | IPS en ligne                            |
| <b>Agent GLPI</b>       | 1.19               | pc-client                          | Inventaire du poste                     |
| <b>x11vnc</b>           | 0.9.16             | pc-client                          | Prise en main à distance                |
| <b>Postfix, Dovecot</b> | 3.8 / 2.3          | srv-glpi                           | Messagerie locale relevée par GLPI      |

## 03 Virtualisation et réseau

Le laboratoire tourne sur VirtualBox, sur un hôte Windows 11 où Hyper-V est actif. Cette contrainte a dicté plusieurs choix de configuration.

| Paramètre          | srv-glpi                        | pc-client                       |
|--------------------|---------------------------------|---------------------------------|
| Processeurs        | 1 vCPU, PAE/NX activé           | 1 vCPU, PAE/NX activé           |
| Mémoire            | 4096 Mo                         | 2048 Mo                         |
| Disque             | 25 Go (VDI dynamique)           | 20 Go (VDI dynamique)           |
| Carte réseau       | virtio-net, réseau NAT glpi-net | virtio-net, réseau NAT glpi-net |
| Adresse MAC        | 08:00:27:FB:88:DB               | 08:00:27:2D:58:58               |
| Adresse réservée   | 192.168.1.10                    | 192.168.1.20                    |
| Paravirtualisation | Par défaut                      | Par défaut                      |

### Réseau NAT glpi-net

Un réseau NAT VirtualBox (et non le NAT par défaut, propre à chaque VM) permet aux deux machines de se voir tout en sortant sur Internet. Le serveur DHCP intégré distribue des baux avec réservation par adresse MAC. Le relais DNS de VirtualBox ne répondant pas aux requêtes (incident n°2, section 14), l'option DHCP 6 impose directement les résolveurs publics 1.1.1.1 et 9.9.9.9.

```
VBoxManage natnetwork add --netname glpi-net --network "192.168.1.0/24" --enable --dhcp on
VBoxManage dhcpserver modify --network=glpi-net --set-opt=6 "1.1.1.1 9.9.9.9"
VBoxManage dhcpserver modify --network=glpi-net --mac-address=080027FB88DB --fixed-address=192.168.1.10
VBoxManage dhcpserver modify --network=glpi-net --mac-address=0800272D5858 --fixed-address=192.168.1.20
VBoxManage natnetwork modify --netname glpi-net --port-forward-4 "ssh-cli:tcp[:] :2223: [192.168.1.20] :22"
```

La seule redirection de port conservée vise le client (SSH d'administration depuis l'hôte). Le serveur n'a aucune redirection : depuis l'hôte, il n'est administrable qu'en rebond par le client puis le tunnel.

### Contrainte Hyper-V

Hyper-V actif sur l'hôte force VirtualBox en mode d'exécution dégradé. Conséquences constatées : plantage du noyau invité avec deux vCPU (corrigé en passant à un seul), et snapshots à chaud inutilisables (sauvegarde mémoire à 0,5 Mo/s puis blocage). Règle d'exploitation : **snapshots uniquement VM éteinte**.



## 04 Serveur GLPI

GLPI 11 sur une pile Apache, PHP 8.3 et MariaDB, exposé uniquement en HTTPS, installé par un script rejouable.

### Installation

Le script `scripts/serveur/etape02-glpi.sh` enchaîne : installation des paquets, sécurisation de MariaDB (équivalent non interactif de `mysql_secure_installation`), création de la base `glpi` et de l'utilisateur dédié, import des fuseaux horaires, téléchargement de la dernière version stable de GLPI depuis GitHub, génération du certificat, hôte virtuel, durcissement PHP, puis installation de la base par la console GLPI :

```
srv-glpi$ sudo -u www-data php bin/console db:install --db-host=localhost --db-name=glpi \
--db-user=glpi --db-password="<secret>" --default-language=fr_FR --no-interaction --
force
srv-glpi$ sudo rm -f /var/www/glpi/install/install.php
srv-glpi$ sudo chmod 640 /var/www/glpi/config/config_db.php
```

Les scripts longs sont lancés comme service transitoire ( `systemd-run --unit=etape02 ...` ) afin de survivre à la fermeture de la session SSH, avec journal dans `/var/log/etape02-glpi.log`.

### Hôte virtuel Apache

La racine web est le dossier `public/` de GLPI : les fichiers de configuration, la base de fichiers et le code hors de ce dossier ne sont jamais servis. Le port 80 ne fait que rediriger vers HTTPS. Trois en-têtes de sécurité sont ajoutés.

```

<VirtualHost *:443>
    ServerName glpi.local
    ServerAlias 192.168.1.10 10.8.0.1
    DocumentRoot /var/www/glpi/public
    SSLEngine on
    SSLCertificateFile /etc/ssl/certs/glpi.crt
    SSLCertificateKeyFile /etc/ssl/private/glpi.key
    Header always set X-Content-Type-Options "nosniff"
    Header always set X-Frame-Options "SAMEORIGIN"
    Header always set Referrer-Policy "strict-origin-when-cross-origin"
    <Directory /var/www/glpi/public>
        Require all granted
        RewriteEngine On
        RewriteCond %{HTTP:Authorization} ^(.+)$
        RewriteRule .* - [E=HTTP_AUTHORIZATION:%{HTTP:Authorization}]
        RewriteCond %{REQUEST_FILENAME} !-f
        RewriteRule ^(.*)$ index.php [QSA,L]
    </Directory>
</VirtualHost>

```

Le certificat est auto-signé (RSA 2048, un an), avec les noms alternatifs `glpi.local` , `192.168.1.10` et `10.8.0.1` , ce qui permet à l'agent GLPI de vérifier le certificat plutôt que de désactiver la vérification.

## Durcissement PHP et comptes

| Élément                                                       | Valeur | Effet                                             |
|---------------------------------------------------------------|--------|---------------------------------------------------|
| <code>session.cookie_httponly</code>                          | On     | Cookie de session inaccessible à JavaScript (XSS) |
| <code>session.cookie_secure</code>                            | On     | Cookie transmis uniquement en HTTPS               |
| <code>session.cookie_samesite</code>                          | Lax    | Protection CSRF complémentaire à celle de GLPI    |
| <code>upload_max_filesize</code> , <code>post_max_size</code> | 20M    | Pièces jointes des tickets                        |
|                                                               |        |                                                   |

| Élément                                                                                             | Valeur                                                                                       | Effet                                                        |
|-----------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|--------------------------------------------------------------|
| <b>Comptes</b> <code>glpi</code> , <code>tech</code> , <code>normal</code> , <code>post-only</code> | mots de passe aléatoires (bcrypt)                                                            | Suppression des mots de passe par défaut connus publiquement |
| <b>Utilisateur MariaDB</b> <code>glpi</code>                                                        | droits limités à la base <code>glpi</code><br>+ lecture de <code>mysql.time_zone_name</code> | Moindre privilège                                            |

Arborescence utile : application dans `/var/www/glpi` , journaux applicatifs dans `/var/www/glpi/files/_log/` ( `php-errors.log` , `cron.log` , `mailgate.log` ), journaux Apache dans `/var/log/apache2/glpi_*.log` .

## 05 Tunnel VPN WireGuard

WireGuard relie les deux machines par un tunnel chiffré 10.8.0.0/24. Il constitue l'unique chemin vers GLPI, SSH et VNC.

### Choix et principes

- **WireGuard** plutôt qu'OpenVPN : intégré au noyau Linux, suite cryptographique fixe (Curve25519, ChaCha20-Poly1305, BLAKE2s), configuration minimale donc peu d'erreurs possibles.
- **Clé pré-partagée** en plus des paires de clés : couche symétrique supplémentaire sur l'échange de clés, réponse à l'exigence « sécuriser le tunnel ».
- **AllowedIPs restrictif** côté serveur ( 10.8.0.2/32 ) : le serveur n'accepte pour ce pair que sa seule adresse VPN, aucune autre plage ne peut transiter par lui.
- **Clés générées sur chaque machine**, jamais transmises ; fichiers en `/etc/wireguard/` avec droits `600` , propriétaire root.

### Configuration du serveur

```
# /etc/wireguard/wg0.conf - srv-glpi
[Interface]
Address      = 10.8.0.1/24
ListenPort   = 51820
PrivateKey   = <secret>

[Peer]
PublicKey     = ePI1eUfg5a4h2Piw45kchrA5d4uaJiJDy5CS5LEWlS0=
PresharedKey  = <secret>
AllowedIPs    = 10.8.0.2/32
```

### Configuration du client

```
# /etc/wireguard/wg0.conf - pc-client
[Interface]
Address      = 10.8.0.2/24
PrivateKey   = <secret>

[Peer]
PublicKey     = TkedrVa2N5pj/8Q1ECLlENOPW24bXuiUAZC6Kin91Rs=
PresharedKey  = <secret>
Endpoint      = 192.168.1.10:51820
AllowedIPs    = 10.8.0.0/24
PersistentKeepalive = 25
```

Le service `wg-quick@wg0` est activé au démarrage sur les deux machines. Le client résout `glpi.local` vers `10.8.0.1` par `/etc/hosts`, de sorte que le navigateur, l'agent et les scripts utilisent toujours l'adresse du tunnel. Aucun masquage NAT n'est configuré : le client ne parle qu'au serveur, pas à travers lui.

## Vérification

```
srv-glpi$ sudo wg show          # handshake récent, compteurs de transfert
pc-client$ ping -c 3 10.8.0.1   # bloqué par l'IPS depuis l'étape 08 : utiliser curl
pc-client$ curl -sk -o /dev/null -w "%{http_code}\n" https://glpi.local/  # 200
```

## 06 Pare-feu et protection SSH

UFW applique une politique « tout refusé en entrée » sur le serveur, avec une seule ouverture côté LAN, le port WireGuard. Les services ne sont autorisés que sur l'interface du tunnel.

```
srv-glpi$ sudo ufw default deny incoming
srv-glpi$ sudo ufw default allow outgoing
srv-glpi$ sudo ufw allow 51820/udp comment WireGuard
srv-glpi$ sudo ufw allow in on wg0 to any port 443 proto tcp comment GLPI-via-VPN
srv-glpi$ sudo ufw allow in on wg0 to any port 80 proto tcp comment redirection-HTTPS
srv-glpi$ sudo ufw allow in on wg0 to any port 22 proto tcp comment SSH-via-VPN
srv-glpi$ sudo ufw enable
```

Règles résultantes dans `/etc/ufw/user.rules` :

```
-A ufw-user-input -p udp --dport 51820 -j ACCEPT
-A ufw-user-input -i wg0 -p tcp --dport 443 -j ACCEPT
-A ufw-user-input -i wg0 -p tcp --dport 80 -j ACCEPT
-A ufw-user-input -i wg0 -p tcp --dport 22 -j ACCEPT
```

L'activation s'est faite via un service détaché : la session SSH par le LAN qui l'a lancée est coupée par la règle elle-même, ce qui est le comportement attendu. Depuis, l'administration passe par le client puis le tunnel :

```
hôte$ ssh -i ~/.ssh/glpi-lab -o ProxyCommand="ssh -i ~/.ssh/glpi-lab -p 2223 -W %h:%p
user@127.0.0.1" user@10.8.0.1
```

### fail2ban

La prison `sshd` par défaut est active (bannissement après plusieurs échecs d'authentification). Elle protège l'accès SSH même à l'intérieur du tunnel, où seuls des pairs authentifiés circulent, mais dont un poste pourrait être compromis.

### Pare-feu du client

Le client applique lui aussi UFW : port 22 ouvert (administration depuis l'hôte), port 5900 (VNC) autorisé uniquement sur `wg0`.

### Interaction avec l'IPS

Les règles UFW sont évaluées *après* le passage par Suricata (chaîne `ufw-before-input` ). Le mode « repeat » de NFQUEUE est indispensable pour que les paquets acceptés par l'IPS reviennent dans les règles UFW : sans lui, le pare-feu est court-circuité. Voir sections 08 et 14.

## 07 Double authentification

GLPI 11 intègre une authentification à deux facteurs par code temporaire (TOTP, RFC 6238). Elle est activée et rendue obligatoire pour tous les comptes.

| Clé de configuration (contexte core) | Valeur                 | Signification                                              |
|--------------------------------------|------------------------|------------------------------------------------------------|
| <code>2fa_enforced</code>            | 1                      | Tout utilisateur doit enrôler un second facteur            |
| <code>2fa_grace_days</code>          | 2                      | Délai laissé pour l'enrôlement après la première connexion |
| <code>2fa_grace_date_start</code>    | 2026-09-03<br>10:22:17 | Début du délai de grâce                                    |

```
srv-glpi$ cd /var/www/glpi
srv-glpi$ sudo -u www-data php bin/console config:set 2fa_enforced 1
srv-glpi$ sudo -u www-data php bin/console config:set 2fa_grace_days 2
```

Fonctionnement : à la connexion, après le mot de passe, GLPI demande le code à six chiffres généré par l'application d'authentification de l'utilisateur (Aegis, FreeOTP, Google Authenticator ou KeePassXC). Le secret est partagé une seule fois via un QR code lors de l'enrôlement ; des codes de secours à usage unique sont fournis. Un administrateur peut désenrôler un compte avec `php bin/console security:disable_2fa`.

La double authentification n'a pas été étendue à SSH (module PAM google-authenticator) : l'accès SSH est déjà conditionné à l'appartenance au VPN et à une clé. C'est un choix documenté, voir section 16.



## 08 IPS Suricata

Suricata 8 fonctionne en mode prévention : chaque paquet entrant ou sortant du serveur est soumis à son verdict avant les règles du pare-feu. Il voit le trafic du tunnel déchiffré, donc les vraies requêtes GLPI.

### Installation et configuration

Paquet du dépôt officiel OISF ( `ppa:oisf/suricata-stable` ), règles Emerging Threats Open maintenues par `suricata-update` . Modifications de `/etc/suricata/suricata.yaml` par rapport au fichier livré :

```
vars:
  address-groups:
    HOME_NET: "[192.168.1.0/24,10.8.0.0/24]"      # LAN + tunnel

  rule-files:
    - suricata.rules                          # règles ET Open (≈ 52 700)
    - /etc/suricata/rules/local.rules          # règles du laboratoire

  nfq:                                         # mode IPS
    mode: repeat
    repeat-mark: 1
    repeat-mask: 1
```

### Mode NFQUEUE

Le service livré démarre Suricata en capture passive (af-packet). Une surcharge systemd le lance sur la file netfilter 0 :

```
# /etc/systemd/system/suricata.service.d/override.conf
[Service]
ExecStart=
ExecStart=/usr/bin/suricata -c /etc/suricata/suricata.yaml --pidfile /run/suricata.pid -q
0 -D -vvv
```

Le renvoi du trafic vers cette file est inscrit dans `/etc/ufw/before.rules` , juste après l'acceptation de l'interface locale et avant l'acceptation des connexions établies, de façon persistante :

```
-A ufw-before-input -m mark ! --mark 0x1/0x1 -j NFQUEUE --queue-num 0 --queue-bypass
-A ufw-before-output -m mark ! --mark 0x1/0x1 -j NFQUEUE --queue-num 0 --queue-bypass
```

Cycle d'un paquet : il arrive non marqué, est envoyé à Suricata ; si Suricata le rejette ( `drop` ), il disparaît ; s'il l'accepte, le mode *repeat* le marque (bit 1) et le réinjecte au même point de la chaîne, où la condition `! --mark` le laisse continuer vers les règles UFW. `--queue-bypass` laisse passer le trafic si Suricata n'est pas démarré : choix de disponibilité, le retirer donne un comportement « fermé en cas de panne ».

## Règles locales

```
# /etc/suricata/rules/local.rules
alert tcp any any -> $HOME_NET 22 (msg:"LAB - Connexion SSH vers le serveur";
flow:to_server; flags:S;
    sid:90000001; rev:1; classtype:not-suspicious;)
drop http any any -> $HOME_NET any (msg:"LAB - Tentative de lecture de /etc/passwd
bloquee"; flow:to_server;
    http.uri; content:"/etc/passwd"; nocase; sid:90000002; rev:1; classtype:web-
application-attack;)
drop icmp any any -> $HOME_NET any (msg:"LAB - Ping vers le serveur bloque par l'IPS";
itype:8;
    sid:90000003; rev:1; classtype:not-suspicious;)
```

Ces règles servent de preuve de blocage indépendante d'Internet, le site de test habituel `testmyids.org` étant injoignable. Les journaux sont dans `/var/log/suricata/` : `fast.log` (une ligne par alerte), `eve.json` (événements détaillés, dont `alert.action` à `blocked` ou `allowed`), `stats.log` (compteurs `ips.accepted`, `ips.blocked`).

### Délai de chargement

Avec un seul vCPU, Suricata met environ une minute à charger ses 52 700 règles après chaque démarrage. Pendant ce délai, le bypass laisse passer tout le trafic : attendre la ligne « Engine started » du journal avant tout test.

## 09 Poste client et agent GLPI

---

Le poste client est un Xubuntu 24.04 (bureau XFCE, adapté aux 2 Go de mémoire imposés). L'agent GLPI y remonte l'inventaire au serveur, à travers le tunnel.

Côté serveur, l'inventaire natif de GLPI (disponible depuis la version 10, qui remplace FusionInventory) est activé : clé `enabled_inventory` du contexte `inventory` , point d'entrée `https://glpi.local/front/inventory.php` .

Côté client, l'agent est installé par l'installateur Perl officiel et configuré dans `/etc/glpi-agent/conf.d/00-install.cfg` :

```
server      = https://glpi.local/front/inventory.php
ca-cert-file = /etc/glpi-agent/glpi.crt
tag         = salle-formation
```

Le certificat du serveur a été récupéré à travers le tunnel ( `openssl s_client` ) et fourni à l'agent, qui vérifie donc l'identité du serveur à chaque envoi. Le service `glpi-agent` tourne en permanence et envoie un inventaire complet toutes les 24 heures (fréquence réglable dans GLPI) ; `sudo glpi-agent -force` déclenche un envoi immédiat. Le poste apparaît dans Parc → Ordinateurs avec matériel, logiciels (environ 1 800 paquets), disques, interfaces réseau (dont les adresses LAN et VPN) et le tag.

## 10 Contrôle à distance

x11vnc partage l'écran réel du poste client. Il n'écoute que sur l'adresse VPN, et GLPI expose le lien de prise en main depuis la fiche de l'ordinateur.

```
# /etc/systemd/system/x11vnc.service – pc-client
[Unit]
Description=Serveur VNC (x11vnc) sur le tunnel VPN uniquement
After=display-manager.service wg-quick@wg0.service
Wants=wg-quick@wg0.service
[Service]
ExecStart=/usr/bin/x11vnc -auth guess -display :0 -rfbauth /etc/x11vnc.pass -no6 \
        -listen 10.8.0.2 -rfbport 5900 -forever -shared -noxdamage
Restart=on-failure
[Install]
WantedBy=multi-user.target
```

Le mot de passe VNC est stocké haché dans `/etc/x11vnc.pass` (root, 600). Deux barrières limitent l'exposition : l'écoute restreinte à `10.8.0.2`, et la règle UFW `5900/tcp on wg0`. Un scan depuis le LAN ne voit pas le port.

Intégration GLPI : Configuration → Liens externes → « Prise en main VNC », lien `vnc://[IP]:5900`, associé au type Ordinateur. GLPI substitue `[IP]` par chaque adresse inventoriée du poste ; l'onglet Liens de la fiche propose donc `vnc://10.8.0.2:5900`, à ouvrir avec un client VNC (Remmina, TigerVNC Viewer) depuis un poste membre du VPN.

## 11 Collecteur de mails

GLPI relève une boîte IMAP et transforme chaque message en ticket. La boîte est fournie par une messagerie locale au serveur, sans dépendance externe ni donnée réelle.

### Messagerie locale

| Composant                   | Paramètres retenus                                                                                                                                                                                    |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Postfix                     | <code>inet_interfaces = loopback-only</code> , <code>inet_protocols = ipv4</code> , <code>myhostname = srv-glpi.local</code> , destinations locales uniquement : aucun relais, aucun port SMTP exposé |
| Dovecot                     | <code>listen = 127.0.0.1</code> , <code>disable_plaintext_auth = no</code> (acceptable car réservé à la boucle locale), boîtes mbox dans <code>/var/mail/</code>                                      |
| Compte <code>support</code> | Compte système sans shell, mot de passe aléatoire dans <code>/root/mail-support.env</code>                                                                                                            |

### Collecteur et tâche automatique

| Objet GLPI                                 | Valeur                                                                                                       |
|--------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| Collecteur « Support par mail »            | serveur <code>{localhost:143/imap/notls}INBOX</code> , identifiant <code>support</code> , actif              |
| Action automatique <code>mailgate</code>   | mode CLI, fréquence 120 s                                                                                    |
| Cron système <code>/etc/cron.d/glpi</code> | <code>* * * * * www-data /usr/bin/php /var/www/glpi/front/cron.php</code>                                    |
| Utilisateur <code>normal</code>            | adresse <code>normal@srv-glpi.local</code> : GLPI rattache le ticket au demandeur par l'adresse d'expédition |

Le mot de passe du collecteur est chiffré par GLPI avec sa clé d'instance ( `config/glpicrypt.key` ). Il ne peut donc pas être écrit directement en base : le script `scripts/glpi/fix-collector.php` amorce le noyau GLPI comme sa console puis passe par l'API `MailCollector::update()`, qui chiffre correctement la valeur.

## Cheminement d'un mail

1. Un utilisateur envoie un mail à `support@localhost` ; Postfix le dépose dans `/var/mail/support` .
2. Chaque minute, le cron système lance `front/cron.php` , qui exécute `mailgate` si sa fréquence est échue.
3. Le collecteur ouvre la boîte en IMAP, lit les messages non traités, identifie le demandeur par l'adresse d'expédition.
4. Un ticket est créé (titre = sujet, description = corps, source « E-Mail »), visible dans Assistance → Tickets.

## 12 Exploitation et maintenance

Ce qu'un administrateur doit savoir pour faire vivre la plateforme.

### Comptes et secrets

| Secret                         | Emplacement                                                                                                      | Droits                        |
|--------------------------------|------------------------------------------------------------------------------------------------------------------|-------------------------------|
| Mots de passe des comptes GLPI | <code>srv-glpi:/root/glpi-comptes.txt</code>                                                                     | root, 600                     |
| Identifiants MariaDB           | <code>srv-glpi:/root/glpi-db.env</code> et<br><code>/var/www/glpi/config/config_db.php</code>                    | root 600 /<br>www-data<br>640 |
| Boîte support                  | <code>srv-glpi:/root/mail-support.env</code>                                                                     | root, 600                     |
| Clés WireGuard                 | <code>/etc/wireguard/*.key</code> , <code>*.psk</code> sur chaque machine                                        | root, 600                     |
| Mot de passe VNC               | <code>pc-client:/root/vnc-mdp.txt</code> , haché dans<br><code>/etc/x11vnc.pass</code>                           | root, 600                     |
| Clé SSH d'administration       | poste hôte, <code>~/ .ssh/glpi-lab</code> ; publique dans<br><code>~user/.ssh/authorized_keys</code> des deux VM | utilisateur<br>hôte           |

Le compte système `user` des deux machines dispose de `sudo` sans mot de passe ( `/etc/sudoers.d/90-user-nopasswd` ), un confort de laboratoire à retirer en production.

### Procédures courantes

| Opération          | Marche à suivre                                                                                                                      |
|--------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| Ordre de démarrage | srv-glpi d'abord, attendre une minute (Suricata), puis pc-client. Le tunnel se rétablit seul grâce au keepalive.                     |
| Snapshot           | VM éteinte uniquement : <code>VBoxManage snapshot srv-glpi take "nom"</code> . Snapshots existants : 01-base-installee, 02-glpi-vpn. |
|                    |                                                                                                                                      |

| Opération                      | Marche à suivre                                                                                                                                                                                                                   |
|--------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Ajouter un pair VPN            | Sur le nouveau poste : générer clé et PSK ; sur le serveur : bloc <code>[Peer]</code> avec une adresse <code>10.8.0.x/32</code> puis <code>wg synconf wg0 &lt;(wg-quick strip wg0)</code> . Aucune règle UFW à ajouter.           |
| Ajouter un utilisateur GLPI    | Administration → Utilisateurs ; il devra enrôler la 2FA sous deux jours. Renseigner son adresse mail s'il doit ouvrir des tickets par mail.                                                                                       |
| Mettre à jour GLPI             | Snapshot, sauvegarde base ( <code>mysqldump glpi</code> ), extraire la nouvelle archive dans <code>/var/www/glpi</code> en conservant <code>config/</code> et <code>files/</code> , puis <code>php bin/console db:update</code> . |
| Mettre à jour les règles IPS   | <code>sudo suricata-update &amp;&amp; sudo systemctl restart suricata</code> ; vérifier « rules successfully loaded » dans <code>suricata.log</code> .                                                                            |
| Forcer la relève des mails     | <code>UPDATE glpi_crontasks SET lastrun=NULL WHERE name='mailgate'</code> puis <code>php front/cron.php mailgate</code> (sinon la tâche attend son échéance).                                                                     |
| Restaurer les tableaux de bord | <code>scripts/glpi/restore-dashboards.php</code> recrée Central, Parc et Assistance depuis les définitions internes.                                                                                                              |
| Sauvegarde                     | Base : <code>mysqldump glpi</code> ; fichiers : <code>/var/www/glpi/files</code> et <code>config</code> ; configurations système listées dans le dépôt.                                                                           |

## Journaux à surveiller

| Journal                                                         | Contenu                                                                         |
|-----------------------------------------------------------------|---------------------------------------------------------------------------------|
| <code>/var/log/suricata/eve.json</code> , <code>fast.log</code> | Alertes et blocages de l'IPS ( <code>jq 'select(.event_type=="alert")'</code> ) |
| <code>/var/log/ufw.log</code>                                   | Paquets refusés par le pare-feu (préfixe <code>[UFW BLOCK]</code> )             |
| <code>fail2ban-client status sshd</code>                        | Adresses bannies                                                                |
| <code>/var/log/apache2/glpi_access.log</code>                   | Requêtes HTTP, dont les envois d'inventaire de l'agent                          |
|                                                                 |                                                                                 |



| Journal                                                             | Contenu                                       |
|---------------------------------------------------------------------|-----------------------------------------------|
| <code>/var/www/glpi/files/_log/</code>                              | Erreurs PHP, actions automatiques, collecteur |
| <code>journalctl -u wg-quick@wg0</code> , <code>sudo wg show</code> | État du tunnel                                |

## 13 Couverture des risques de sécurité

Positionnement de l'infrastructure face aux familles de risques du cahier des charges. Les mesures applicatives internes à GLPI (contrôle d'accès par profil, protection CSRF, journal d'audit) sont celles du produit, non modifiées.

| Risque                                          | Mesures en place                                                                                                                                       | Couverture                   |
|-------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------|
| <b>Exposition des services</b>                  | Seul UDP 51820 ouvert côté LAN ;<br>HTTPS, SSH et VNC uniquement dans<br>le tunnel ; scans LAN « filtered »                                            | Couvert                      |
| <b>Interception en transit</b>                  | WireGuard (chiffrement + PSK) et<br>HTTPS à l'intérieur ; cookies Secure                                                                               | Couvert                      |
| <b>Vol ou devinette de mot de passe</b>         | 2FA obligatoire, mots de passe par<br>défaut remplacés, hachage bcrypt,<br>fail2ban sur SSH, accès SSH par clé                                         | Couvert                      |
| <b>Attaques web (injection, traversée, XSS)</b> | IPS en ligne sur le trafic déchiffré, en-<br>têtes de sécurité, racine web<br><code>public/</code> , HttpOnly/SameSite,<br>protections natives de GLPI | Couvert                      |
| <b>Défaut de journalisation</b>                 | Suricata (eve.json), UFW, fail2ban,<br>Apache, journaux GLPI ; aucune<br>donnée secrète dans les journaux                                              | Couvert                      |
| <b>Composants vulnérables</b>                   | Ubuntu 24.04 LTS à jour, GLPI 11.0.8 et<br>agent 1.19 (dernières versions),<br>Suricata 8 du dépôt éditeur, règles ET<br>mises à jour                  | Couvert                      |
| <b>Secrets exposés</b>                          | Aucun secret dans le dépôt Git<br>( <code>.gitignore</code> ), fichiers 600 root, mot<br>de passe du collecteur chiffré par GLPI                       | Couvert                      |
| <b>Certificat non reconnu</b>                   | Auto-signé : l'agent le vérifie<br>explicitement, les navigateurs affichent<br>un avertissement                                                        | Partiel (voir<br>section 16) |

| Risque                 | Mesures en place                                                                      | Couverture   |
|------------------------|---------------------------------------------------------------------------------------|--------------|
| Disponibilité de l'IPS | --queue-bypass : arrêt de Suricata = trafic non inspecté mais toujours filtré par UFW | Choix assumé |

## 14 Incidents rencontrés et corrections

Chaque incident a été diagnostiqué, corrigé et intégré aux scripts ou à la configuration. Ils font partie du retour d'expérience du projet.

| # | Symptôme                                                                                  | Cause                                                                                                                                |
|---|-------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| 1 | Plantage du noyau pendant l'installation d'Ubuntu (trace <code>cpu_startup_entry</code> ) | VirtualBox en mode dégradé sous Hyper-V, instable avec plusieurs vCPU                                                                |
| 2 | Installateur bloqué sur la vérification du miroir                                         | Le relais DNS du réseau NAT VirtualBox (192.168.1.1) ne répondait pas                                                                |
| 3 | Snapshot à chaud interminable puis VM figée                                               | Sauvegarde mémoire à 0,5 Mo/s sous Hyper-V, puis blocage de VirtualBox                                                               |
| 4 | Script d'installation mort silencieusement                                                | Processus tué à la fermeture de la session SSH ; puis pipeline <code>tr   head</code> incompatible avec <code>set -o pipefail</code> |
|   |                                                                                           |                                                                                                                                      |

| # | Symptôme                                                                         | Cause                                                                                                      |
|---|----------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
| 5 | Boucle sur l'écran de connexion du client                                        | Dossier personnel créé par root avant l'installation du compte                                             |
| 6 | Collecteur : « cannot login, user or password wrong »                            | Mot de passe inséré en clair alors que GLPI attend une valeur chiffrée                                     |
| 7 | Ports du serveur de nouveau ouverts depuis le LAN après l'activation de Suricata | En mode NFQUEUE « accept », le verdict de Suricata fait sortir le paquet de la chaîne avant les règles UFW |
| 8 | Tableaux de bord GLPI supprimés par erreur                                       | Bouton corbeille du tableau de bord, sans confirmation                                                     |

#### Enseignement principal

L'incident n°7 est le plus instructif : l'IPS fonctionnait, le pare-feu semblait actif, et pourtant le serveur était exposé. Seul un retest complet des preuves (scan de ports depuis le LAN) l'a révélé. Toute modification de la chaîne de filtrage doit être suivie d'un rejeu des tests de la recette.

## 15 Dépôt Git et reproductibilité

Le dépôt `glpi-securise-infra` contient tout ce qui permet de rejouer l'installation, sans aucun secret.

|                                              |                                                                                                                                                |
|----------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>README.md</code>                       | architecture, correspondance avec le cahier de recettes,                                                                                       |
| <code>procédure</code>                       |                                                                                                                                                |
| <code>docs/</code>                           | guide de montage (HTML, PDF), légende des captures, cette                                                                                      |
| <code>documentation</code>                   |                                                                                                                                                |
| <code>scripts/serveur/</code>                | <code>etape02-glpi.sh</code> · <code>etape06-suricata.sh</code> · <code>etape06b-tests.sh</code> ·                                             |
| <code>etape09-mail.sh</code>                 |                                                                                                                                                |
| <code>scripts/glpi/</code>                   | <code>fix-collector.php</code> · <code>restore-dashboards.php</code>                                                                           |
| <code>scripts/demo/</code>                   | <code>demo-vpn.sh</code> · <code>demo-ips.sh</code> · <code>demo-firewall.sh</code> · <code>demo-mail.sh</code> ·                              |
| <code>demo-ips-log.sh</code>                 |                                                                                                                                                |
| <code>config/serveur/</code>                 | <code>apache2</code> , <code>wireguard</code> (expurgé), <code>ufw</code> , <code>suricata</code> , <code>systemd</code> , <code>mail</code> , |
| <code>cron</code> , <code>config GLPI</code> |                                                                                                                                                |
| <code>config/client/</code>                  | <code>wireguard</code> (expurgé), <code>glpi-agent</code> , <code>systemd</code> ( <code>x11vnc</code> ), <code>ufw</code>                     |
| <code>tools/</code>                          | <code>virtualbox-setup.ps1</code> · <code>azerty_inject.py</code>                                                                              |

Historique : une branche `main` et une branche `feat/NN-...` par étape du cahier de recettes, fusionnées sans avance rapide pour conserver la trace de chaque lot. Le `.gitignore` exclut clés, mots de passe, fichiers `.env`, images disques, ISO et vidéos ; un `.gitattributes` impose les fins de ligne Linux aux scripts.

Rejouer l'installation sur deux VM neuves suit l'ordre du guide de montage : configuration VirtualBox ( `tools/virtualbox-setup.ps1` ), étape 02 par script, VPN et pare-feu à partir des fichiers de `config/`, 2FA par la console GLPI, étape 06 par script, agent et VNC à partir de `config/client/`, étape 09 par script puis `fix-collector.php`.

## 16 Limites et évolutions

---

- **Certificat auto-signé.** Suffisant en recette ; en production, une autorité interne (ou ACME si le nom est public) supprimerait les avertissements et permettrait la rotation.
- **Double authentification limitée à GLPI.** Le module PAM google-authenticator ajouterait un second facteur à SSH ; il n'a pas été mis en place, l'accès SSH étant déjà conditionné au VPN et à une clé.
- **IPS en bypass.** Le choix de laisser passer le trafic si Suricata s'arrête privilégie la disponibilité. L'alternative « fermé en cas de panne » se règle en retirant `--queue-bypass`.
- **Sudo sans mot de passe** sur le compte d'administration des VM, pour les besoins du montage automatisé. À retirer hors laboratoire.
- **Messagerie locale.** Le collecteur fonctionne à l'identique avec une boîte IMAP externe (changer le serveur et activer TLS dans la configuration du collecteur).
- **Un seul poste d'administration VPN.** Ajouter le poste de l'administrateur comme pair (section 12) permettrait la prise en main VNC et l'accès GLPI sans passer par le client.
- **Sauvegardes.** Aucune sauvegarde automatique n'est planifiée ; un `mysqldump` quotidien vers un volume dédié serait la première évolution.
- **Performances.** Un seul vCPU par VM allonge le chargement des règles Suricata et l'installation des paquets ; sans Hyper-V sur l'hôte, deux vCPU seraient possibles.

## A Annexes

### A.1 Adresses et ports

| Machine          | Interface       | Adresse         | Services en écoute                                           |
|------------------|-----------------|-----------------|--------------------------------------------------------------|
| srv-glpi         | enp0s3<br>(LAN) | 192.168.1.10/24 | UDP 51820 (WireGuard) — tout le reste filtré                 |
|                  | wg0 (VPN)       | 10.8.0.1/24     | TCP 22 SSH, 80 redirection, 443 GLPI                         |
| pc-client        | enp0s3<br>(LAN) | 192.168.1.20/24 | TCP 22 SSH (administration depuis l'hôte via 127.0.0.1:2223) |
|                  | wg0 (VPN)       | 10.8.0.2/24     | TCP 5900 VNC                                                 |
| srv-glpi (local) | lo              | 127.0.0.1       | TCP 3306 MariaDB, 25 Postfix, 143 Dovecot                    |

### A.2 Commandes de vérification

```
# Tunnel
srv-glpi$ sudo wg show
# Pare-feu et exposition
srv-glpi$ sudo ufw status verbose
pc-client$ nmap -Pn -p 22,80,443 192.168.1.10      # attendu : filtered
pc-client$ nmap -Pn -p 22,80,443 10.8.0.1        # attendu : open
# IPS
srv-glpi$ sudo suricata -T -c /etc/suricata/suricata.yaml
srv-glpi$ sudo iptables -S ufw-before-input | grep NFQUEUE
pc-client$ curl --max-time 8 "http://10.8.0.1/index.php?file=/etc/passwd" # attendu :
timeout
srv-glpi$ sudo jq -c 'select(.alert.signature_id>=90000001) |
{timestamp,src_ip,action:.alert.action,sig:.alert.signature}' /var/log/suricata/eve.json |
tail
# Inventaire
pc-client$ sudo glpi-agent --force
# Collecteur
srv-glpi$ ./demo-mail.sh "Sujet du ticket"
```



### A.3 Scripts de démonstration

Sur le client : `demo-vpn.sh` (tunnel et scans), `demo-ips.sh` (attaque bloquée). Sur le serveur : `demo-firewall.sh`, `demo-mail.sh`, `demo-ips-log.sh`. Chacun tient en une commande, sans copier-coller, pour les démonstrations en direct.